

韩天硕

☎ (+86) 173-3953-9195 · ✉ hantianshuo@iie.ac.cn · 🌐 github.com/keymaker-arch

安全研究员 / 漏洞挖掘与利用 / 内核安全

🎓 教育经历

中国科学院大学，信息工程研究所 | 网络空间安全，直博在读 2021.09 – 2027.01 (预计)

- 研究方向：Linux 内核安全、漏洞挖掘与利用、模糊测试、AI for Security。
- 代表成果发表于 IEEE S&P、USENIX Security、ACM CCS 等世界顶级安全会议。

中国农业大学，生命科学学院 | 生物科学，理学学士 2017.09 – 2021.06

- 跨专业保送至中国科学院大学网络空间安全专业直博；曾获全国大学生数学建模竞赛国家级一等奖、CUPT 青年物理学家竞赛华北赛区一等奖、iGEM 国际基因工程机器大赛金奖。

📄 学术成果

- IEEE S&P 26 **NetPanic: The Attack Surface You Can't Syscall**
CCF-A 韩天硕, 曹纵, 董震, 罗夏朴, 宋振宇, 刘剑
47th IEEE Symposium on Security and Privacy (S&P), 2026
摘要：提出 Fuzzer-in-the-Middle 网络协议模糊测试架构，首次系统地测试 Linux 内核网络栈远程攻击面，发现 15+ 个远程可触发内核漏洞；负责核心架构设计与实现、LibAFL 定制、漏洞复现、实验评估及论文主要撰写。
- USENIX Sec 24 **CARDSHARK: Understanding and Stabilizing Linux Kernel Concurrency Bugs Against the Odds**
CCF-A 韩天硕, 龚晓锐, 刘剑
33rd USENIX Security Symposium, 2024
摘要：分析 Linux 内核竞争漏洞触发不稳定的根因，提出通用竞争漏洞利用技术，显著提升漏洞利用成功率和可复现性；负责竞争漏洞机理分析、利用技术研发、性能评估与论文主要撰写。
- ACM CCS 26 **Venom: Kernel Fuzzing of Distributed File Systems via Intra-Cluster Protocol Poisoning**
CCF-A 曹纵, 韩天硕 (共同一作), 等.
在投
ACM Conference on Computer and Communications Security (CCS), 2026
摘要：提出 Mutation-in-the-Middle 及静态分析引导变异算法，在内核分布式文件系统发现 30+ 个内核漏洞；负责变异算法设计与实现、实验设计、漏洞复现及结果分析。
- Black Hat 26 **Wire to Ring Zero: The Remote Kernel Attack Surface That Years of Fuzzing Never Reached**
Industry 韩天硕, 曹纵
在投
Black Hat USA, 2026
摘要：从工业攻防视角梳理远程内核攻击面，提出面向 Linux/Windows 内核网络栈实现的中间人模糊测试方法。
- ACM CCS 25 **Reviving Discarded Vulnerabilities: Exploiting Previously Unexploitable Linux Kernel Bugs Through Control Metadata Fields**
CCF-A 章豪, 陆杰, 陈绍民, 韩天硕, 张伯伦, 刘剑, 龚晓锐
32nd ACM Conference on Computer and Communications Security (CCS), 2025
摘要：提出基于内核结构体关键元数据字段操控的利用技术，增强弱漏洞原语场景下的利用能力并扩展可利用漏洞范围；参与核心思路制定、评估实验设计及审稿意见回复。
- Catalysts 22 **Whole-genome sequence and comparative analysis of *Trichoderma asperellum* ND-1**
SCI 郑锋振, 韩天硕, et al.
IF=4.16
Catalysts 12(4), 2022
摘要：负责基因组数据分析与科学数据可视化，辅助揭示该菌株木质纤维素降解酶系统。

Fuzzing Linux Kernel Framework	NetPanic：面向 Linux 内核网络栈的 FitM 模糊测试框架 设计区别于 Syzkaller 的在途中间人模糊测试架构，面向 NFS/CIFS/NFSD/ksmbd 等网络路径提升远程攻击面覆盖；基于 LibAFL 深度定制变异、执行、反馈、调度等核心组件，独立完成 40K+ 行 Rust/C 实现；支撑 IEEE S&P 2026 论文与多项远程可触发 Linux 内核 CVE 发现。	2023.11 – 至今
Fuzzing Static Analysis Mutation Algorithm	Venom：Mutation-in-the-Middle 变异算法 设计静态分析引导的高效变异算法，针对 Fuzzer-in-the-Middle 架构中的网络协议状态、消息依赖和污染传播进行优化；基于 LibAFL 与 LLVM IR 实现，代码规模 50K+ 行 (Rust/C/Python)，支撑分布式文件系统漏洞发现。	2026.03 – 至今
Agentic Security Audit Fully-Automated	自动化漏洞审计与复现 Agent 基于 ClaudeCode/Codex SDK 构建端到端全自动安全审计 Agent，覆盖漏洞发现、环境搭建、复现、PoC 生成和报告撰写；在 HTTPD、QEMU、GStreamer、ImageMagick、libexif 等开源项目中发现 16 个漏洞并获得 CVE。	2026.03 – 2026.04
Rootkit Linux Kernel Stealth	Linux 内核 Rootkit 与隐蔽机制研究 独立实现自身隐藏、端口隐藏、权限提升、文件/进程隐藏、开机自启等核心机制，用于内核攻防技术验证；强调轻量化、高隐蔽性与跨版本兼容，支持 Linux 2.6 至 6.3 系列内核并规避常见 Rootkit 检测策略。	2023.12 – 2024.05
Kernel Dev Unix-like Operational	类 Linux 内核开发 从零实现可运行的类 Linux 内核，覆盖引导、内存管理、进程调度、系统调用和文件系统等核心子系统；代码规模约 20K 行 (C/x86 汇编)。	2020.12 – 2021.05

🚩 安全贡献

Linux 内核漏洞 5 项

- **CVE-2025-38089**: sunrpc 空指针解引用，可远程触发内核崩溃
- **CVE-2025-38051**: CIFS 客户端 cifs_fill_dirent 释放后重用
- **CVE-2025-40210**: NFSD 远程 COMPOUND 请求内存分配失败拒绝服务
- **CVE-2025-40212**: NFSD 伪根文件句柄引用计数泄漏，导致 UAF 与拒绝服务
- **CVE-2026-23220**: ksmbd SMB2 请求处理无限循环远程拒绝服务

QEMU 漏洞 7 项

- **CVE-2026-7180**: 暂未公开披露
- **CVE-2026-8341**: UEFI 认证头长度校验缺失，导致整数下溢
- **CVE-2026-8343**: VNC 扩展剪贴板长度校验错误，导致堆越界读取
- **CVE-2026-8348**: 9pfs 扩展属性 FID 无限创建，导致宿主机内存耗尽
- **CVE-2026-9238**: 9pfs 目录读取请求触发超大内存分配，导致拒绝服务
- **CVE-2026-48914**: virtio-blk SCSI 请求长度校验缺失，导致堆越界写入
- **CVE-2026-48915**: UEFI 十六进制字符串解析单字节越界写入

其他漏洞 9 项

- **Apache HTTPD**: **CVE-2026-28780** (mod_proxy_ajp AJP 消息堆越界写入)、**CVE-2026-34032** (mod_proxy_ajp 嵌入字符串解析越界读取)
- **ImageMagick**: **CVE-2026-40312** (MSL 解码器 XML 分组解析堆越界写入)
- **libexif**: **CVE-2026-40385** (Nikon MakerNote 32 位无符号整数溢出)、**CVE-2026-40386** (Fuji/Olympus MakerNote 尺寸校验整数下溢)
- **GStreamer**: **CVE-2026-53701** (H.266/VVC PPS 越界写入)、**CVE-2026-53702** (H.265 SEI 栈溢出)、**CVE-2026-53703** (RealMedia 音频越界读取)、**CVE-2026-53704** (RealMedia FILEINFO 越界读取)

👥 教学与社区贡献

- 2023 年中国科学院大学《恶意软件发现与分析》课程助教
- 2026 年 ISSA 审稿人

✂ 技术能力与其他

- **内核安全**：Linux 内核漏洞挖掘与利用、远程攻击面分析、Rootkit 机制、二进制逆向与利用。
- **安全能力**：熟练掌握网络、系统和密码等网络安全基础；熟悉 LibAFL、AFL++、Syzkaller、LLVM、CodeQL 等模糊测试和静态分析框架；熟练使用 GDB、IDA 等程序调试和逆向工具；熟练使用各种渗透测试工具。
- **编程语言**：精通 C 和 Rust；熟练掌握 Python、Shell、x86 汇编、 $\text{\LaTeX}$ ，可以使用各种主流编程语言。
- **AI 与 Harness**：熟练掌握 Agentic 编程工作流，可以快速完成开发任务和安全测试任务。
- **外语能力**：英语读写能力与母语者接近，可熟练阅读、撰写英文论文和技术文档。